



The MentorSphere

# Data protection impact assessment: primary learner profile

Version 1.0

## Document details

**Version:** 1.0

**Assessment date:** 31 July 2026

**Controller and owner:** Luke Turner, The MentorSphere

**Status:** completed for owner residual-risk sign-off. No unmitigated high risk has been identified. Processing must not begin until the recorded safeguards, integration tests and policy publication are complete.

## Assessment wording

### 1. Why a DPIA is required

The form concerns children and other potentially vulnerable learners and may collect health-related special-category information. A parent or another adult may submit information about the learner. Although the expected volume is small and there is no profiling or automated decision-making, the nature and context create a risk of significant privacy, emotional and autonomy impacts if information is excessive, inaccurate, disclosed or used without valid authority.

The DPIA was started before production processing and follows the ICO sequence of describing the processing, assessing necessity and proportionality, identifying risks, selecting safeguards and recording residual risk.

### 2. Nature, scope, context and purposes

#### Nature

The direct, unlisted website form collects:

- respondent identity, contact details, relationship and communication preferences;
- learner identity, date of birth, education stage and subjects;
- ordinary educational background, strategies and session preferences;
- optional structured and narrative needs, diagnosis, neurodiversity, EHCP, support and background information where the special-category route is chosen;

- general authority, privacy acknowledgement, conditional explicit consent, a conditional learner consent route and conditional authority confirmation; and
- operational metadata including submission ID, processing timestamps, notification status and retention controls.

The form does not request identity documents, full medical records, financial information, passwords, biometric data, location tracking or recordings. It does not conduct profiling, behavioural advertising, automated eligibility decisions or automated safeguarding decisions.

## Scope

- Data subjects: primary-age learners, respondents and potentially family members or professionals mentioned in relevant text.
- Vulnerability: learners are children and may also be disabled, neurodivergent, anxious or otherwise vulnerable.
- Volume: low-volume sole-trader intake, one row per submitted learner profile, with no bulk import.
- Geography: predominantly online support across the UK. Cloud service processing may involve international processing under supplier contractual safeguards.
- Duration: prospective intake data is reviewed against the approved six-month rule. Active-client, safeguarding and legal records follow their separately applicable arrangements.

## Context

The respondent deliberately opens an unlisted form after contact or direction from Luke. The learner may not be the respondent. The power and understanding difference between an adult respondent and a child makes transparency, authority and data minimisation especially important.

## Purposes

- respond to a request for education support;
- assess whether the requested support falls within service scope;
- prepare a proportionate introductory discussion;
- plan and personalise support if a relationship begins;
- communicate using the chosen method;
- maintain a minimal audit record of privacy, consent, authority, notification and retention actions; and
- meet safeguarding or legal obligations where a separate issue arises.

No data is collected for unrelated marketing or sold.

### 3. Data flow

1. The respondent enters information in the browser. Answers remain in page memory and are not written to URLs, cookies, local storage or session storage.
2. The browser obtains a Turnstile token and sends the JSON request to the same-origin Cloudflare Worker.
3. The Worker applies page and submission flags, origin and content-type checks, a body-size limit, honeypot handling, field allowlists and conditional consent, learner consent route and authority validation. It rejects every structured or narrative special-category field when the respondent chose No.
4. The Worker sends the Turnstile token, submission ID and connection information needed for verification to Cloudflare Turnstile. Learner answers are not included in the Turnstile verification request.
5. After validation, the Worker signs a short-lived request with HMAC and forwards it to Google Apps Script.
6. Apps Script independently checks the HMAC, timestamp, form shape, special-category relationship rule and duplicate submission ID.
7. Apps Script writes one text-formatted row to an owner-only Google Sheet.
8. Apps Script sends a minimal notification to the monitored business inbox. It contains a receipt timestamp and restricted Sheet link, but no respondent or learner answers. A narrow Gmail rule matches the exact sender, recipient and subject, keeps it out of Spam, applies the Learner profile notifications label and marks it important.
9. Luke reviews the private row, updates record and retention status, and removes records when no longer required.

On a Worker, Turnstile or Apps Script failure, the page displays a generic retry message and does not clear the answers. No answer values are intentionally logged.

### 4. Roles, processors and access

The MentorSphere is the controller. Luke Turner is the business owner and only planned production Sheet user at launch.

Cloudflare provides website delivery, Worker execution, Turnstile and network protection. Its customer DPA describes Cloudflare as processor or sub-processor for customer personal data, includes security and sub-processing commitments, and provides mechanisms for restricted UK transfers. The architecture minimises Cloudflare content handling by disabling answer logs and forwarding only after validation.

Google provides Workspace, Sheets, Apps Script, Gmail notification delivery and related infrastructure. Google Workspace processing is governed by the applicable agreement and Cloud Data Processing Addendum. Google states that data-region controls depend on the Workspace edition and the covered service and data. This assessment therefore does not assume that every Sheet or Apps Script data element remains in the UK. Supplier transfer terms, account configuration and sub-processors must remain under review.

Production Drive sharing is owner-only. Link sharing is disabled. No third party receives learner answers through the notification.

## 5. Lawful basis, consent and authority

### Article 6

- Article 6(1)(b) applies to the respondent's own information where processing is necessary to take steps requested by that person before a possible contract.
- Article 6(1)(f) applies to proportionate ordinary learner and third-party information needed for suitability and support planning, subject to the separate child-specific legitimate interests assessment.

### Article 9

Article 9(2)(a), explicit consent, applies to optional health, disability, SEND and neurodiversity information.

The form has a required Yes or No choice before the special-category fields. Choosing No leaves all structured and narrative support fields hidden and cleared, does not require consent and still permits submission. Choosing Yes reveals separate, unticked explicit-consent and authority controls and a required single-choice learner consent route.

At initial launch, the special-category route is available only where the relationship is Parent or Guardian or carer and the respondent confirms parental responsibility or documented legal authority. Education or support professionals, other family members and Other respondents are told not to provide health, disability, SEND, neurodiversity, diagnosis or EHCP information and are directed to a separate documented-authority workflow. The Worker and Apps Script reject attempts to bypass this rule.

The learner consent route records either that the learner cannot yet understand and give informed consent and the authorised adult is consenting, or that the learner understands the use and authorised the respondent to communicate consent. The exact selected route and its wording version are recorded with respondent details, received date, explicit-consent wording version, authority wording version and consent status. Missing, altered and out-of-context routes are rejected by the browser, Worker and Apps Script.

Luke must take the learner's wishes and competence seriously throughout. The selected route supports the initial decision but does not replace contextual review. If a learner appears able to understand and objects, shows distress or gives information inconsistent with the selected route, Luke must pause use of the optional information and review consent and authority before personalising support from it.

## 6. Consent withdrawal

Withdrawal requests are sent to [luke@thementorsphere.co.uk](mailto:luke@thementorsphere.co.uk).

Luke must:

1. identify the relevant record and verify the requester's identity and authority proportionately;
2. record the withdrawal date and change consent status to Withdrawn;
3. stop using the special-category information;

4. remove or irreversibly redact structured special-category cells and special-category content within free-text cells unless another Article 9 condition applies to a separate purpose already disclosed to the individual;
5. retain ordinary information only where its separate Article 6 basis and retention arrangements continue to apply;
6. retain only a minimal withdrawal record where needed to honour the request;
7. confirm completion to the requester; and
8. explain that withdrawal does not affect processing that occurred lawfully before withdrawal and may limit personalisation that depended on the removed information.

Withdrawal does not automatically end ordinary support and carries no penalty.

## 7. Necessity, proportionality and minimisation

- Fixed choices are used where possible to reduce open-ended collection.
- Special-category collection is optional and segregated.
- The restricted relationship rule prevents routine third-party special-category submission.
- Narrative support fields are optional, length-limited and available only within the special-category route. Choosing No clears them in the browser, while the Worker and Apps Script reject crafted values without using keyword scanning.
- The form requests no evidence, reports or documents.
- A direct-contact and alternative-format route remains available.
- Suitability is reviewed by a person and is not determined automatically.
- The information is not reused for marketing or unrelated profiling.
- One integrated profile avoids repeated collection across tutoring, coaching and education support where support needs legitimately evolve.

The ordinary information and optional special-category route are proportionate to an informed support-planning discussion. The processing would become disproportionate if the fields, recipients, decisions or purposes expanded without reassessment.

## 8. Retention and deletion

- Where no service relationship begins, intake responses are normally deleted six months after the last meaningful contact.
- Where a service relationship begins, intake information may become part of the active learner record and follows applicable client-record arrangements.
- Test, duplicate and unnecessary submissions are removed as soon as reasonably possible.
- Safeguarding information may be retained separately where required under the Safeguarding Policy or relevant legal obligations.
- Each row has record status, last meaningful contact date, review date, safeguarding or legal hold and minimal retention notes.
- A saved monthly filter identifies prospective records due for review and not on hold.
- Consent status and withdrawal date support removal and redaction after withdrawal.

### Accidental special-category information without consent

If optional health, disability, SEND or neurodiversity information is provided without the required consent, The MentorSphere will not use it for personalisation and will remove or redact it as soon as reasonably possible, unless it must be handled separately for a safeguarding or legal purpose.

Operationally, Luke must not use the information; must remove or irreversibly redact it promptly; may contact the respondent without repeating it to offer the correct consent or information-sharing route; must retain only the minimum administrative record needed to evidence the action; and must handle any safeguarding concern separately under the Safeguarding Policy or applicable legal obligation.

## 9. Security and breach considerations

Security measures include:

- separate page and submission release flags that fail closed;
- Turnstile, honeypot, same-origin, content-type and body-size checks;
- strict server-side allowlists and conditional validation;
- HMAC authentication, short timestamp window and constant-time comparison;
- independent Apps Script shape validation;
- duplicate submission locking;
- formula-injection protection and text-formatted Sheet cells;
- owner-only Drive sharing;
- answer-free notifications;
- an exact sender, recipient and subject Gmail routing rule that keeps the fixed notification in the monitored Inbox, labels it and marks it important;
- no sensitive browser storage, analytics, URL parameters or intentional answer logging;
- generic client and API errors;
- secret rotation and non-repository secret storage; and
- fictional-only testing followed by immediate cleanup.

If a suspected breach occurs, Luke must contain access, preserve minimal evidence, assess affected data and individuals, follow the business breach procedure and determine whether notification to the ICO or affected individuals is required. Answers must not be copied into diagnostic tickets or ordinary email.

## 10. Consultation

The design incorporates the owner's requirements, the live form source, the approved privacy wording, the child-specific LIA and current ICO guidance. Direct consultation with children was not undertaken before this limited sole-trader launch because the form is completed by an authorised adult and the processing is small in scale. This decision must be reviewed if the form is offered directly to children, the audience expands or feedback indicates that the privacy explanation is not understood.

The form provides age-appropriate-information duties through the authority confirmation and Privacy Policy. Luke must make reasonable adjustments or provide an alternative format when requested.

## 11. Risk method

Likelihood and severity are each scored from 1 to 5. The risk score is likelihood multiplied by severity:

- 1 to 4: low;
- 5 to 9: medium;
- 10 to 14: significant; and
- 15 to 25: high.

Any residual high risk requires consultation with the ICO before processing starts.

## 12. Risk register

| Risk                                                                                     | Initial score   | Measures                                                                                                                                                                                                 | Residual score |
|------------------------------------------------------------------------------------------|-----------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------|
| Child is unaware of, does not understand or objects to the processing                    | 12, significant | Versioned learner consent route, adult authority confirmation, age-appropriate privacy sharing, contextual competence review and learner involvement                                                     | 8, medium      |
| Special-category information submitted without valid explicit consent                    | 15, high        | Optional Yes or No route, all narrative and structured fields hidden and cleared on No, separate unticked consent, versioned learner route, Worker and Apps Script rejection, prompt redaction procedure | 6, medium      |
| Professional or other third party submits special-category information without authority | 15, high        | Restricted relationships, all special-category fields hidden and cleared, clear separate-route wording, independent server rejection                                                                     | 6, medium      |
| Excessive special-category detail entered in free text                                   | 12, significant | Optional route-only fields, relevance warnings, no document upload, length limits, contextual owner review and deletion                                                                                  | 8, medium      |
| Inaccurate third-party information affects suitability or planning                       | 9, medium       | No automated decisions, introductory discussion, correction rights and contextual review                                                                                                                 | 4, low         |
| Unauthorised access to the Sheet                                                         | 15, high        | Owner-only sharing, business account, restricted folder, account security, HMAC and access review                                                                                                        | 6, medium      |
| Secret or endpoint compromise permits forged rows                                        | 15, high        | High-entropy HMAC, rotation, short freshness window, duplicate protection, no secret in repository                                                                                                       | 4, low         |
| Formula-like input executes in the spreadsheet                                           | 12, significant | Text number format and prefix protection for formula-leading characters                                                                                                                                  | 2, low         |
| Duplicate retry creates multiple learner records or emails                               | 9, medium       | Stable submission ID, Script Lock and duplicate lookup before append                                                                                                                                     | 2, low         |
| Notification discloses answers                                                           | 12, significant | Fixed minimal template with no submitted fields, tested against monitored inbox                                                                                                                          | 2, low         |
| Notification is overlooked in Spam                                                       | 9, medium       | Exact sender, recipient and subject filter; Never Spam; monitored label; mark important; fictional delivery check                                                                                        | 2, low         |
| Submission failure causes loss or misleading success                                     | 9, medium       | Fail-closed upstream result, generic retry response and browser answer preservation                                                                                                                      | 3, low         |
| Answers appear in browser, Worker or diagnostic logs                                     | 15, high        | No console logging, no browser storage, invocation logging disabled, no answer values in application errors                                                                                              | 4, low         |

| Risk                                                            | Initial score   | Measures                                                                                                               | Residual score |
|-----------------------------------------------------------------|-----------------|------------------------------------------------------------------------------------------------------------------------|----------------|
| Data retained longer than necessary                             | 12, significant | Automatic review date, monthly filter, record status, hold flag and documented deletion process                        | 4, low         |
| Consent withdrawal is not actioned completely                   | 12, significant | Consent status and withdrawal date, documented cell removal and redaction procedure, minimal completion record         | 6, medium      |
| Supplier or international-transfer risk                         | 12, significant | Google and Cloudflare DPAs, contractual transfer mechanisms, minimisation, restricted access and periodic terms review | 8, medium      |
| Account compromise or device loss                               | 15, high        | Business account security, least-privilege sharing, owner access only and prompt access revocation                     | 6, medium      |
| Safeguarding information is deleted or retained incorrectly     | 12, significant | Separate hold field, safeguarding policy exception, minimal notes and individual review                                | 6, medium      |
| Function creep into marketing, profiling or automated decisions | 12, significant | Purpose limitation, no analytics answers, documented prohibited uses and mandatory DPIA review trigger                 | 3, low         |

No residual score is high. The remaining medium risks are inherent to authorised adult collection of children's educational information and use of major cloud processors. They are accepted only subject to owner sign-off and continued operation of every listed safeguard.

### 13. Required actions and completion evidence

| Action                                                                        | Status                                                                                                                                                                                               |
|-------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Implement approved conditional consent and authority logic                    | Completed and tested                                                                                                                                                                                 |
| Enforce restricted relationships in Worker and Apps Script                    | Completed and tested in the browser, Worker and Apps Script validation layers                                                                                                                        |
| Record consent route, wording versions, timestamp, status and withdrawal date | Completed in the 48-column production schema and verified by fictional smoke test                                                                                                                    |
| Complete child-specific LIA                                                   | Completed                                                                                                                                                                                            |
| Prepare final Privacy Policy V1.5 wording                                     | Completed in the launch branch, not published                                                                                                                                                        |
| Confirm owner-only Google Workspace access                                    | Completed                                                                                                                                                                                            |
| Rotate HMAC and deploy authorised Apps Script version                         | Completed using the MentorSphere business account                                                                                                                                                    |
| Store all production Worker secrets without deploying production              | Completed in undeployed Worker versions                                                                                                                                                              |
| Pass fictional production-path smoke test and remove test data                | Completed on 31 July 2026 against the final 48-column schema. The production Sheet was returned to one header row and zero response rows, and fictional notification emails were removed from Inbox. |
| Confirm no answer logging                                                     | Completed through browser inspection and answer-free local Worker request logs                                                                                                                       |



| Action                                              | Status                                                                                                                                               |
|-----------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------|
| Route the fixed notification to the monitored Inbox | Completed with an exact sender, recipient and subject Gmail rule; fictional delivery passed Inbox, label, Important, not-Spam and answer-free checks |
| Publish approved Privacy Policy V1.5                | Blocked until final owner approval                                                                                                                   |
| Enable form page and submissions                    | Blocked until final owner approval                                                                                                                   |

## 14. Outcome and sign-off

The processing is necessary and proportionate for the limited intake purpose after applying the documented controls. The assessment identifies no unmitigated high risk. Production processing must not start if any high-risk safeguard fails or if the residual risk changes materially.

Owner sign-off:

- Owner decision: Approved for the limited primary learner intake purpose described in this assessment, subject to all documented safeguards, restrictions and review triggers remaining in operation.
- Residual risks accepted: Yes. I accept the documented low and medium residual risks. This acceptance does not apply if the purpose, fields, recipients, processors, authority rules, retention arrangements or technical safeguards materially change.
- Signature: Luke Turner
- Approval date: 31 July 2026

## Official sources

- ICO DPIA process: <https://ico.org.uk/for-organisations/uk-gdpr-guidance-and-resources/accountability-and-governance/data-protection-impact-assessments-dpias/how-do-we-do-a-dpia/>
- ICO DPIAs and children's risks: <https://ico.org.uk/for-organisations/uk-gdpr-guidance-and-resources/childrens-information/childrens-code-guidance-and-resources/age-appropriate-design-a-code-of-practice-for-online-services/2-data-protection-impact-assessments/>
- ICO special-category conditions and explicit consent: <https://ico.org.uk/for-organisations/uk-gdpr-guidance-and-resources/lawful-basis/special-category-data/what-are-the-conditions-for-processing/>
- Google Cloud terms directory and Workspace processing terms: <https://cloud.google.com/product-terms>
- Google Workspace service-specific data-region terms: [https://workspace.google.com/intl/en\\_uk/terms/service-terms/](https://workspace.google.com/intl/en_uk/terms/service-terms/)
- Cloudflare customer DPA: <https://www.cloudflare.com/en-gb/cloudflare-customer-dpa/>